BÁO CÁO KIỂM THỬ MIỀN GIÁ TRỊ VÀ PHÂN TÍCH GIÁ TRỊ BIÊN

TÍNH NĂNG FR-17: QUẢN LÝ MÃ GIẢM GIÁ (COUPON CRUD) (POOL C)

- **Mã sinh viên:** 23120127
- **Họ và tên:** Dương Trọng Hòa
- **Hệ thống được kiểm thử (SUT):** EShop Platform (`http://localhost:5173` / Backend API `http://localhost:3000`)
- **Kỹ thuật áp dụng:** Domain Testing (Equivalence Partitioning - EP) & Boundary Value Analysis (3-Value BVA theo chuẩn ISTQB)
- **Thời gian thực hiện:** 2026-10-18

---

1. ĐẶC TẢ YÊU CẦU & PHÂN TÍCH BIẾN ĐẦU VÀO (SPECIFICATION ANALYSIS)

1.1 Trích xuất đặc tả FR-17 từ System Requirements Specification

> - **FR-17: Quản lý Mã Giảm Giá (Coupon CRUD)**
>   - Phân hệ Web Admin cho phép Quản trị viên quản lý danh sách mã giảm giá.
>   - **Thêm mới mã giảm giá (Create):** Quản trị viên nhập thông tin mã gồm:
>   - `code`: Mã giảm giá (chuỗi ký tự, duy nhất trong hệ thống).
>   - `discount_type`: Loại giảm giá (theo phần trăm `'percent'` hoặc số tiền cố định `'fixed'`).
>   - `discount_value`: Giá trị giảm giá (phải là số dương > 0; nếu loại `percent` thì trong khoảng $1..100$, nếu loại `fixed` thì > 0).
>   - `min_order_amount`: Giá trị đơn hàng tối thiểu để áp dụng mã (số nguyên ≥ 0).
>   - `max_uses_per_user`: Số lần sử dụng tối đa của mỗi người dùng (số nguyên dương ≥ 1).
>   - **Xem danh sách (Read):** Hiển thị toàn bộ mã giảm giá đang có trong hệ thống (`GET /api/coupons`).
>   - **Xóa mã giảm giá (Delete):** Cho phép Quản trị viên xóa mã giảm giá theo `id` (`DELETE /api/admin/coupons/:id`).
> - **Ràng buộc phân quyền & an toàn hệ thống (FR-12, FR-22, SEC-02, SEC-03, SEC-04):**
>   - **Kiểm soát truy cập (Access Control - FR-12, SEC-03):** Các endpoint quản trị `/api/admin/*` bắt buộc phải có JWT Token hợp lệ và người dùng phải có vai trò Quản trị viên (`role = 'admin'`). Người dùng thông thường (`role = 'user'`) hoặc khách vãng lai không được phép tạo hoặc xóa mã.
>   - **Ràng buộc biểu mẫu (FR-22):** Các trường dữ liệu bắt buộc phải có nhãn rõ ràng, thông báo lỗi validation dễ hiểu.
>   - **An ninh chống XSS (SEC-04):** Trường `code` khi nhập mã HTML/Script phải được sanitize hoặc escape an toàn, không được thực thi script trên trình duyệt.

1.2 Điều kiện tiên quyết (Preconditions)

- Môi trường SUT: Frontend chạy tại `http://localhost:5173`, Backend chạy tại `http://localhost:3000`, CSDL `database.sqlite`.
- Tài khoản Quản trị viên (Admin): `admin@eshop.com` / `Admin1234!` (`id = 1`, `role = 'admin'`).
- Tài khoản Người dùng thường (Non-Admin): `test@eshop.com` / `Test1234!` (`id = 2`, `role = 'user'`).

1.3 Danh sách biến đầu vào và ràng buộc kỹ thuật

Tên biến đầu vào	Kiểu dữ liệu	Miền giá trị hợp lệ (Valid Domain)	Ràng buộc kỹ thuật & Nghiệp vụ (Constraints)
`Authorization` **(JWT Token)**	String (HTTP Header)	`Bearer <valid_admin_token>`	**Bắt buộc**: Bắt buộc đăng nhập và người dùng phải có quyền Admin (`role = 'admin'`) theo FR-12 và SEC-03.
`Mã giảm giá` **(`code`)**	String	Chuỗi từ 1 đến 50 ký tự, chữ hoa/số, duy nhất (Unique).	Bắt buộc (FR-22). Không trùng lặp với mã đã có. Escape an toàn chống Stored XSS (SEC-04).
`Loại giảm giá` **(`discount_type`)**	Enum String	`'percent'` hoặc `'fixed'`	Bắt buộc chọn 1 trong 2 loại hợp lệ. Xác định ý nghĩa cho `discount_value`.
`Mức giảm` **(`discount_value`)**	Number (Integer/Float)	Nếu `percent`: $[1..100]$ Nếu `fixed`: $[1..\text{Infinity})$	Bắt buộc là số dương > 0. Không được bằng 0, không được âm. Loại `percent` không được vượt quá 100%.
`Đơn hàng tối thiểu` **(`min_order_amount`)**	Number (Integer)	$[0..\text{Infinity})$	Bắt buộc là số nguyên ≥ 0. Mặc định bằng 0 nếu không yêu cầu giá trị đơn tối thiểu. Cấm số âm.
`Lượt dùng tối đa` **(`max_uses_per_user`)**	Number (Integer)	$[1..\text{Infinity})$	Bắt buộc là số nguyên dương ≥ 1. Cấm số 0 hoặc số âm.
`ID mã giảm giá` **(`coupon_id`)** *(cho Delete)*	Integer	Số nguyên dương ≥ 1, đang tồn tại trong bảng `coupons`.	Bắt buộc khi gọi `DELETE /api/admin/coupons/:id`. ID không tồn tại phải trả về 404 Not Found.

---

2. PHÂN VÙNG TƯƠNG ĐƯƠNG (EQUIVALENCE PARTITIONING - EP)

Dựa trên các biến đầu vào thuần túy của tính năng Quản lý Mã Giảm Giá (FR-17), phân chia miền giá trị thành các lớp tương đương:

Biến đầu vào	Lớp tương đương	Loại	Giá trị đại diện	Mục tiêu kiểm thử
`Authorization`	**EC1.1**	Valid	Token có `role = 'admin'`	Tài khoản Quản trị viên hợp lệ thực hiện thao tác CRUD.

Biến đầu vào	Lớp tương đương	Loại	Giá trị đại diện	Mục tiêu kiểm thử
	EC1.2	Invalid	Token có `role = 'user'`	Tài khoản thông thường cố tình gọi API Admin (Kiểm tra RBAC - SEC-03).
	EC1.3	Invalid	`""` (Không gửi Token)	Không có Token xác thực, gọi API trái phép (Kiểm tra 401 Unauthorized).
`Mã code`	**EC2.1**	Valid	`"SUMMER2026"`	Chuỗi ký tự hợp lệ, chưa từng tồn tại trong CSDL.
	EC2.2	Invalid	`""` (Chuỗi rỗng)	Bỏ trống mã giảm giá.
	EC2.3	Invalid	`"WELCOME10"` (Đã có sẵn)	Nhập mã bị trùng lặp với mã đã tồn tại trong CSDL.
	EC2.4	Security	`"<script>alert(1)</script>"`	Nhập payload mã độc XSS vào mã code (SEC-04).
`Loại giảm giá`	**EC3.1**	Valid	`'percent'`	Giảm giá theo tỷ lệ phần trăm (1% – 100%).
	EC3.2	Valid	`'fixed'`	Giảm giá theo số tiền cố định (VND).
`Mức giảm` (`discount_value`)	**EC4.1**	Valid	`20` (khi type = 'percent')	Tỷ lệ phần trăm hợp lệ nằm trong khoảng $[1..100]$.
	EC4.2	Valid	`50000` (khi type = 'fixed')	Số tiền giảm cố định hợp lệ (> 0).
	EC4.3	Invalid	`0`	Mức giảm bằng 0 (Biên dưới không hợp lệ).
	EC4.4	Invalid	`-50000`	Mức giảm là số âm (< 0).
	EC4.5	Invalid	`150` (khi type = 'percent')	Phần trăm giảm vượt quá 100% (> 100).
`Đơn tối thiểu` (`min_order_amount`)	**EC5.1**	Valid	`0`	Biên Min hợp lệ: Đơn hàng tối thiểu bằng 0 ₫ (áp dụng mọi đơn).
	EC5.2	Valid	`200000`	Số tiền đơn tối thiểu hợp lệ (> 0).
	EC5.3	Invalid	`-10000`	Số tiền đơn tối thiểu là số âm (< 0).
`Lượt dùng tối đa` (`max_uses_per_user`)	**EC6.1**	Valid	`1`	Biên Min hợp lệ: Mỗi user được dùng 1 lần.
	EC6.2	Valid	`5`	Số lần dùng hợp lệ (> 1).
	EC6.3	Invalid	`0`	Lượt dùng bằng 0 (Biên dưới không hợp lệ).
	EC6.4	Invalid	`-1`	Lượt dùng là số âm (< 0).
`ID mã giảm giá` (`coupon_id`)	**EC7.1**	Valid	`ID = 2`	ID số nguyên dương tồn tại trong CSDL (Xóa thành công).
	EC7.2	Invalid	`ID = 99999`	ID số nguyên dương không tồn tại trong CSDL (Phải trả về 404).

3. PHÂN TÍCH GIÁ TRỊ BIÊN (BOUNDARY VALUE ANALYSIS - 3-VALUE BVA)

Áp dụng kỹ thuật 3-Value BVA theo chuẩn ISTQB ($Min - 1, Min, Min + 1, Nominal, Max - 1, Max, Max + 1$):

3.1 Bảng phân tích giá trị biên 3 giá trị cho FR-17

Biến kiểm thử	Ranh giới (Boundary)	Min - 1	Min	Min + 1	Nominal	Max - 1	Max	Max + 1
`discount_value` *(percent)*	Đoạn hợp lệ $[1..100]$	`0` *(Invalid)*	`1` *(Valid)*	`2` *(Valid)*	`20`	`99` *(Valid)*	`100` *(Valid)*	`101` *(Invalid)*
`discount_value` *(fixed)*	Số dương ≥ 1	`0` *(Invalid)*	`1` *(Valid)*	`2` *(Valid)*	`50.000`	*N/A (Open)*	*N/A (Open)*	*N/A (Open)*
`min_order_amount`	Số không âm ≥ 0	`-1` *(Invalid)*	`0` *(Valid)*	`1` *(Valid)*	`200.000`	*N/A (Open)*	*N/A (Open)*	*N/A (Open)*
`max_uses_per_user`	Số nguyên dương ≥ 1	`0` *(Invalid)*	`1` *(Valid)*	`2` *(Valid)*	`3`	*N/A (Open)*	*N/A (Open)*	*N/A (Open)*
`coupon_id` *(Delete)*	ID tồn tại trong CSDL	`0` *(Invalid)*	`1` *(Valid)*	`2` *(Valid)*	`Existing ID`	—	`Max ID`	`99999` *(Invalid)*

4. KẾT QUẢ THỰC THI KIỂM THỬ THỰC TẾ (TEST EXECUTION RESULTS)

Tất cả 14 kịch bản kiểm thử đã được thực thi trực tiếp trên hệ thống EShop thực tế (Frontend `http://localhost:5173`, Backend `http://localhost:3000`, CSDL `database.sqlite`). Toàn bộ hình ảnh bằng chứng đã được lưu trữ đầy đủ tại thư mục `screenshots/fr17/`.

Mã TC	Kịch bản kiểm thử	Dữ liệu đầu vào (Input)	Kết quả mong đợi (Expected Result)	Kết quả thực tế (Actual Result)	Trạng thái	Bằng chứng (Screenshot)
EXE-01	Tạo mã giảm giá loại phần trăm hợp lệ (Nominal Percent)	`code: "SUMMER2026"`, `type: "percent"`, `value: 20`, `min_order: 200000`, `max_uses: 1`	Thêm mới thành công (HTTP 200), hiển thị trong danh sách mã và lưu vào CSDL.	Thêm mới thành công mã giảm giá loại phần trăm SUMMER2026.	**PASS**	`EXE-01_Valid_Create_Percent_Coupon.png`
EXE-02	Tạo mã giảm giá loại cố định với đơn tối thiểu bằng 0 (Biên Min `min_order_amount`)	`code: "FREE50K"`, `type: "fixed"`, `value: 50000`, `min_order: 0`, `max_uses: 3`	Tạo thành công mã giảm giá (HTTP 200), chấp nhận biên Min `min_order = 0`.	Tạo thành công mã giảm giá loại cố định FREE50K với đơn tối thiểu bằng 0 ₫ (Biên Min hợp lệ của min_order_amount).	**PASS**	`EXE-02_Valid_Create_Fixed_Coupon_ZeroM`
EXE-03	Xóa mã giảm giá đang tồn tại hợp lệ	`DELETE /api/admin/coupons/:id` với ID của coupon đang tồn tại	Xóa mã thành công (HTTP 200), mã biến mất khỏi danh sách và bảng `coupons`.	Xóa thành công mã giảm giá đang tồn tại.	**PASS**	`EXE-03_Valid_Delete_Coupon.png`
EXE-04	Kiểm tra phân quyền: Người dùng thường tạo mã giảm giá	Token của `test@eshop.com` (`role = 'user'`), payload tạo mã giảm 1.000.000 ₫	Hệ thống từ chối (HTTP 403 Forbidden), chỉ cho phép Admin theo FR-12, SEC-03.	Lỗ hổng phân quyền nghiêm trọng: Tài khoản thường (`test@eshop.com`) có thể tự tạo mã giảm giá 1.000.000 ₫ thành công (HTTP 200 OK). Backend không kiểm tra quyền admin.	**FAIL**	`EXE-04_Bug_Critical_NonAdmin_Create_Co`
EXE-05	Kiểm tra phân quyền: Người dùng thường xóa mã giảm giá	Token của `test@eshop.com` (`role = 'user'`), gọi `DELETE /api/admin/coupons/:id`	Hệ thống từ chối (HTTP 403 Forbidden), chỉ cho phép Admin xóa mã.	Hệ thống cho phép người dùng thông thường gửi request xóa thành công mã giảm giá trong hệ thống (HTTP 200 OK). Backend thiếu kiểm tra `role === 'admin'`.	**FAIL**	`EXE-05_Bug_Critical_NonAdmin_Delete_Co`
EXE-06	Kiểm tra xác thực Token: Gọi API tạo mã khi không có Token	Gửi request `POST /api/admin/coupons` không có Header `Authorization`	Hệ thống từ chối yêu cầu (HTTP 401 Unauthorized) theo SEC-02.	Hệ thống từ chối yêu cầu tạo mã giảm giá khi không có Token xác thực, trả về mã lỗi HTTP 401.	**PASS**	`EXE-06_Security_Missing_Token_401.png`
EXE-07	Nhập mã giảm giá bị trùng lặp (Duplicate Code)	Tạo coupon với `code = "WELCOME10"` (đã tồn tại trong hệ thống)	Hệ thống từ chối (HTTP 400 Bad Request / 409 Conflict), thông báo mã code đã tồn tại.	Khi nhập mã bị trùng lặp, Backend không xử lý lỗi validation mà để CSDL SQLite văng ngoại lệ `SQLITE_CONSTRAINT: UNIQUE constraint failed: coupons.code`, trả về HTTP 500 Internal Server Error làm treo luồng xử lý.	**FAIL**	`EXE-07_Bug_Duplicate_Code_500_Error.pr`
EXE-08	Mức giảm bằng 0 (Biên Min - 1 của `discount_value`)	`code: "ZEROOFF"`, `type: "fixed"`, `discount_value: 0`, `min_order: 100000`	Hệ thống từ chối (HTTP 400 Bad Request), yêu cầu mức giảm	Backend không kiểm tra ràng buộc số dương của trường `discount_value`, cho phép tạo thành công	**FAIL**	`EXE-08_Bug_BVA_DiscountValue_Zero_Acce`

Mã TC	Kịch bản kiểm thử	Dữ liệu đầu vào (Input)	Kết quả mong đợi (Expected Result)	Kết quả thực tế (Actual Result)	Trạng thái	Bằng chứng (Screenshot)
			phải là số dương > 0.	mã giảm giá có mức giảm bằng 0 (HTTP 200 OK).		
EXE-09	Mức giảm là số âm (`discount_value = -50000`)	`code: "NEGOFF", type: "fixed", discount_value: -50000, min_order: 100000`	Hệ thống từ chối (HTTP 400 Bad Request), cấm giá trị âm.	Tương tự, Backend cho phép tạo mã giảm giá có `discount_value` âm (-50.000 ₫) với HTTP 200 OK.	**FAIL**	`EXE-09_Bug_Negative_DiscountValue_Acce`
EXE-10	Giảm giá phần trăm vượt quá 100% (Biên Max + 1: `discount_value = 150`)	`code: "OVER100", type: "percent", discount_value: 150, min_order: 100000`	Hệ thống từ chối (HTTP 400 Bad Request), thông báo phần trăm chỉ từ 1% đến 100%.	Đối với loại giảm giá percent, Backend cho phép nhập giá trị 150 (> 100%), vi phạm biên Max [1..100], trả về HTTP 200 OK.	**FAIL**	`EXE-10_Bug_BVA_Percent_Over100_Accepte`
EXE-11	Giá trị đơn hàng tối thiểu là số âm (`min_order_amount = -10000`)	`code: "NEGMIN", type: "fixed", discount_value: 20000, min_order: -10000`	Hệ thống từ chối (HTTP 400 Bad Request), yêu cầu đơn tối thiểu ≥ 0.	Backend cho phép tạo mã với `min_order_amount` âm (-10.000 ₫) với HTTP 200 OK.	**FAIL**	`EXE-11_Bug_BVA_MinOrderAmount_Negative_Acc`
EXE-12	Lượt dùng tối đa bằng 0 (Biên Min - 1 của `max_uses_per_user`)	`code: "ZEROUSES", type: "fixed", discount_value: 30000, max_uses: 0`	Hệ thống từ chối (HTTP 400 Bad Request), yêu cầu số lượt dùng ≥ 1.	Backend cho phép tạo mã với `max_uses_per_user = 0` (ngoài biên hợp lệ [1..n]), tuy nhiên khi người dùng F5 tải lại trang Web Admin thì giao diện lại tự động hiển thị số 1 (bất nhất giữa CSDL và UI hiển thị).	**FAIL**	`EXE-12_Bug_BVA_MaxUses_Zero_Accepted.p`
EXE-13	Xóa mã giảm giá với ID không tồn tại (`coupon_id = 99999`)	Gửi request `DELETE /api/admin/coupons/99999`	Hệ thống trả về HTTP 404 Not Found kèm thông báo không tìm thấy mã giảm giá.	Gửi request DELETE tới ID mã giảm giá không tồn tại (99999), API trả về HTTP 200 OK kèm thông báo "Coupon deleted" thay vì 404 Not Found.	**FAIL**	`EXE-13_Bug_Delete_NonExistent_ID_200OK`
EXE-14	Kiểm tra an toàn trước tấn công Stored XSS trong mã Code	Tạo coupon với `code = "<script>alert('XSS')</script>"`	Hệ thống escape an toàn, hiển thị nguyên chuỗi plain text, không thực thi mã JavaScript (SEC-04).	Hệ thống an toàn trước tấn công XSS, chuỗi HTML/script trong mã giảm giá được React frontend tự động escape và hiển thị an toàn dưới dạng plain text.	**PASS**	`EXE-14_Security_XSS_Code_Escaped.png`

5. TỔNG HỢP CÁC LỖI PHÁT HIỆN (DEFECT SUMMARY)

Tổng số test cases thực thi: **14**

- **Passed:** 5/14 (35.71%)
- **Failed (Phát hiện lỗi):** 9/14 (64.29%)

Danh mục 5 nhóm lỗi phát hiện được:

1. **BUG-FR17-01 (Critical - Security / Broken Access Control)**: Thiếu hoàn toàn cơ chế kiểm tra quyền Quản trị viên (`role === 'admin'`) tại các endpoint `POST /api/admin/coupons` và `DELETE /api/admin/coupons/:id`. Bất kỳ người dùng thông thường nào đã đăng nhập (`role = 'user'`) đều có thể tự ý tạo mã giảm giá tùy ý (ví dụ tự giảm 1.000.000 ₫) hoặc xóa mã giảm giá của hệ thống (vi phạm nghiêm trọng FR-12 và SEC-03).

2. **BUG-FR17-02 (High - Crash / Error Handling)**: Khi tạo mã giảm giá có `code` trùng lặp với mã đã có sẵn, Backend không bắt lỗi xác thực mà để CSDL SQLite văng ngoại lệ `SQLITE_CONSTRAINT: UNIQUE constraint failed: coupons.code`, làm trả về HTTP 500 Internal Server Error thay vì HTTP 400 Bad Request hoặc 409 Conflict.
3. **BUG-FR17-03 (High - Data Validation & Boundary Violations)**: Backend thiếu hoàn toàn tầng kiểm tra dữ liệu đầu vào cho các trường số: chấp nhận `discount_value = 0` và âm (`-50000`), chấp nhận `min_order_amount = -10000`, chấp nhận `max_uses_per_user = 0` (đặc biệt khi F5 Web Admin thì giao diện lại tự hiển thị thành 1, gây bất nhất dữ liệu nghiêm trọng).
4. **BUG-FR17-04 (High - Business Logic Violation)**: Đối với loại giảm giá `percent`, Backend không kiểm tra giới hạn trần 100%, cho phép tạo mã giảm giá có tỷ lệ 150% (lớn hơn cả giá trị đơn hàng), vi phạm logic nghiệp vụ thương mại điện tử.
5. **BUG-FR17-05 (Low/Medium - RESTful API Standards)**: Khi gửi request xóa mã giảm giá với `id` không tồn tại (`99999`), Backend không kiểm tra `this.changes === 0` mà vẫn trả về HTTP 200 OK "Coupon deleted", vi phạm chuẩn thiết kế RESTful API (lẽ ra phải trả về HTTP 404 Not Found).